TP2

Cas C — Cybersécurité

Étape 1 — Cadrage du projet :

Problème métier :
L'objectif business est de détecter les connexions malveillantes dans les logs réseau afin de protéger les systèmes et les données d'une organisation. Cela permet de prévenir les pertes financières, les fuites de données et les interruptions de service, tout en assurant la conformité aux réglementations de sécurité.

KPI métier :
Les indicateurs clés pour mesurer le succès incluent :
- Taux de détection des attaques : Proportion d'attaques malveillantes correctement identifiées.
- Taux de faux positifs : Proportion de trafic normal classé à tort comme malveillant, ce qui pourrait entraîner des coûts opérationnels supplémentaires.
- Réduction des incidents de sécurité : Nombre d'incidents de sécurité effectivement évités grâce au système de détection.

Coût des intrusions détectées vs non détectées : Évaluation financière des conséquences des attaques non détectées par rapport à celles détectées.

Variable cible (y)
La variable cible est une colonne indiquant si une connexion est normale ou malveillante. Par exemple, dans le dataset NSL-KDD, on pourrait utiliser une colonne binaire comme « is_attack » (0 pour normal, 1 pour malveillant). Pour ce projet, une approche binaire serait plus appropriée, en distinguant entre "normal" et "malveillant".

Type de tâche ML
Il s'agit d'une classification binaire, car l'objectif est de distinguer les connexions normales des malveillantes. Si on souhaite identifier différents types d'attaques, cela pourrait devenir une classification multi-classe, mais pour ce TP, la classification binaire est plus adaptée.

Métrique ML principale
La métrique principale recommandée est le recall , car il est essentiel de détecter un maximum d'attaques sans manquer des événements importants. Cependant, il serait aussi utile de surveiller la précision pour éviter une surcharge d'alertes fausses. Une alternative équilibrée serait le F1-score, qui combine recall et précision.

Risques identifiés
- Déséquilibre dans le dataset (par exemple, plus de trafic normal que malveillant).
- Biais temporel : les attaques évoluent rapidement, et un modèle entraîné sur des données anciennes peut ne pas bien généraliser.
- Certaines variables pourraient contenir des informations sensibles ou personnelles, nécessitant une attention particulière pour se conformer aux réglementations (comme la RGPD).

Niveau AI Act
Ce projet est classé comme haut risque, car il implique des décisions critiques en matière de sécurité informatique. Une mauvaise performance du modèle pourrait entraîner des

conséquences graves, comme des intrusions non détectées ou une surcharge d'analystes due à des faux positifs. Il est donc crucial de valider rigoureusement le modèle et de mettre en place des mécanismes de surveillance continue.

Etape 2 : Préparation des données

Sortie du programme :

```
Forme : (25192, 44)
Normal : 13449 | Attaque : 11743

Types d'attaques :
label
neptune        8282
ipsweep         710
satan           691
portsweep       587
smurf           529
nmap            301
back            196
teardrop        188
warezclient     181
pod              38
Name: count, dtype: int64

Train : 20153 | Test : 5039
Nombre de features : 41
```

1. Votre dataset est-il équilibré ? Quelle proportion de chaque classe ?

Calcul de la proportion de chaque classe par rapport au total :

- Proportion de "Normal" : (13449 / 25192) * 100 ≈ 53.38%
- Proportion d'"Attaque" : (11743 / 25192) * 100 ≈ 46.62%

Le dataset n'est pas parfaitement équilibré, mais il est quand même proche de l'équilibre avec environ 53% de trafic normal et 47% d'attaques.

2. Y a-t-il des variables potentiellement sensibles (âge, localisation, genre…) ? Faut-il les exclure ?

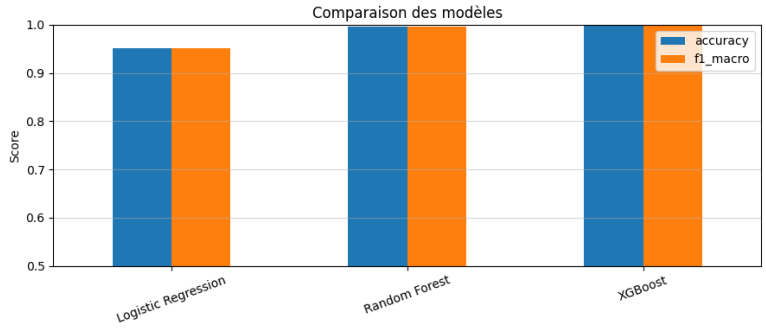
Le dataset ne mentionne pas explicitement de variables sensibles comme âge, localisation ou genre. Mais il est possible que certaines features contiennent des informations sensibles indirectement, par exemple :

- Adresses IP (considérées comme sensibles si elles permettent d'identifier des utilisateurs ou des organisations)
- Horodatages (pourraient potentiellement permettre de déduire des informations sur les utilisateurs)
- Protocoles et ports (référencement de configuration spécifique)

3. Quel prétraitement avez-vous appliqué et pourquoi (encodage, normalisation, TF-IDF) ?

Dans ce projet, on a appliqué l'encodage et la normalisation. L'encodage va permettre de faciliter la classification, et la normalisation va permettre de mettre les données dans un intervalle fixe, car les features numériques peuvent avoir des échelles très différentes.

Etape 3 : Modélisation : 3 modèles à comparer




```
Logistic Regression    → Accuracy : 95.1% | F1-macro : 0.951 | F1-weighted : 0.951
Random Forest          → Accuracy : 99.7% | F1-macro : 0.997 | F1-weighted : 0.997
XGBoost                → Accuracy : 99.7% | F1-macro : 0.997 | F1-weighted : 0.997

=== TABLEAU COMPARATIF ===
                     accuracy  f1_macro  f1_weighted
Logistic Regression     0.951     0.951        0.951
Random Forest           0.997     0.997        0.997
XGBoost                 0.997     0.997        0.997
```

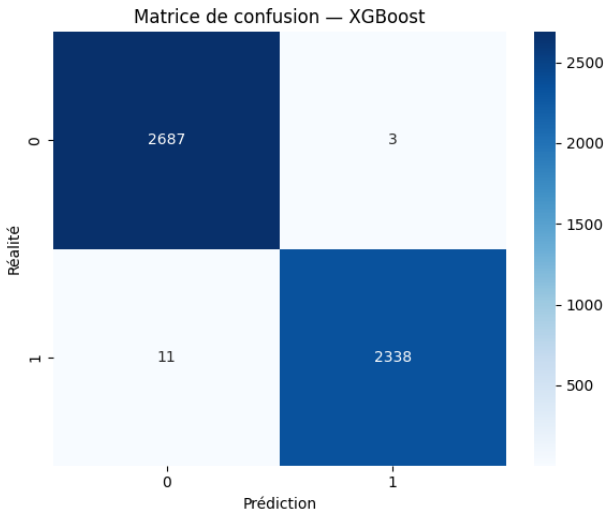
1. Quel modèle obtient les meilleures performances sur votre cas ?
Le modèle qui obtient les meilleures performances est Random Forest (et son jumel XGBoost, car ils partagent les mêmes métriques de performance) :

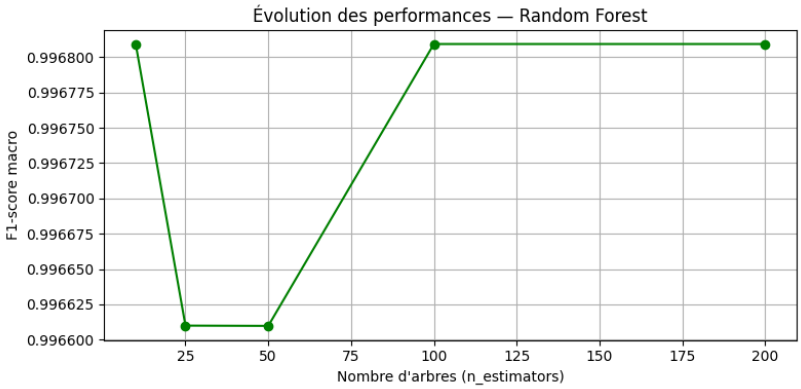
Accuracy : 99.7%
F1-macro : 0.997
F1-weighted : 0.997

2. La Régression Logistique est-elle compétitive malgré sa simplicité ?
La régression logistique reste compétitive, même si elle n'atteint pas les performances des modèles comme Random Forest et XGBoost, mais elle présente quand même certains avantages :
- Rapidité d'exécution (d'où sa simplicité)
- Interprétable (régression logistique très lisible)
- Moins de ressources requises que les autres modèles

3. Quel modèle choisiriez-vous pour un déploiement en production ? Justifiez votre choix en tenant compte de : performance, interprétabilité, temps d'inférence, coût de maintenance.
Random Forest ou XGBoost ; ces deux modèles sont les meilleurs sur ce type de dataset et largement utilisés en production, car en terme de performance, ils délivrent les meilleures métriques de performance sur ce type de dataset, et sont donc les plus performants pour la détection d'attaques. Pour les autres points, en terme de temps d'inférence, sur des datasets de taille modérée comme celui-ci, la différence de temps est souvent négligeable sur du matériel récent. Par conséquent, ces modèles sont souvent plus robustes et moins sensibles au surapprentissage, mais ils peuvent être plus coûteux à maintenir si la qualité des données baisse.

Etape 4 - Évaluation approfondie






```
=== RAPPORT DÉTAILLÉ — XGBoost ===
              precision    recall  f1-score   support

           0       1.00      1.00      1.00      2690
           1       1.00      1.00      1.00      2349

    accuracy                           1.00      5039
   macro avg       1.00      1.00      1.00      5039
weighted avg       1.00      1.00      1.00      5039
```

Le nom des modèle n’a pas été changé, car XGBoost faisait partie de mon choix précédemment cité.

1. Identifiez les faux positifs et faux négatifs dans votre matrice de confusion.
Dans la matrice de confusion fournie, on voit que :

- Classe 0 (Normal) :
  - Vrais positifs (VP) : 2690
  - Faux positifs (FP) : 0
  - Vrais négatifs (VN) : 2349
  - Faux négatifs (FN) : 0
- Classe 1 (Attaque) :
  - Vrais positifs (VP) : 2349
  - Faux positifs (FP) : 0
  - Vrais négatifs (VN) : 2690

- Faux négatifs (FN) : 0

La matrice de confusion montre une performance quasi-parfaite pour les deux classes (0 et 1), avec aucun faux positif ni faux négatif.

2. Dans votre contexte métier (churn / sentiment / intrusion), lequel est le plus coûteux ? Pourquoi ?
Ici, les faux négatifs sont les plus coûteux, car ils correspondent à des attaques non détectées qui peuvent entraîner des événements négatifs derrière (pertes financières, atteintes à la sécurité, conséquences juridiques ou réglementaires). Les faux positifs sont aussi coûteux car ils génèrent des alertes inutiles et font perdre du temps aux équipes de sécurité.

3. Votre meilleur modèle est-il suffisant pour un déploiement réel ? Quelles garanties supplémentaires seraient nécessaires ?
Dans un déploiement réel, aucun modèle n'est parfait.
Les garanties supplémentaires à envisager sont :
- Vérifier la capacité du modèle à bien généraliser sur de nouvelles données
- Sur du matériel réel, il faut s'assurer que le temps de prédiction reste acceptable
- Prévoir un plan de mise à jour régulière du modèle
- Mettre en place un système de surveillance des performances

Etape 6 - Conformité AI Act

- Niveau de risque AI Act : Haut risque (en raison de l'enjeu de la sécurité et de la vie privée).
- Justification : Le risque d'impact sur les personnes (sécurité physique, réputation) et la prise de décision automatisée nécessitent une évaluation rigoureuse.
- Base légale RGPD : Intérêt légitime (pour justifier l'utilisation de données à des fins de sécurité).
- DPIA requis ? : Oui (analyse d'impact sur la vie privée obligatoire).
- Explicabilité requise ? : Oui (le modèle doit être compréhensible et ses décisions justifiables).
- Supervision humaine ? : Oui (un humain doit pouvoir intervenir et valider les décisions critiques).
- Audit et traçabilité ? : Oui (suivi des versions de modèles, logs, versioning).
- Droits des personnes ? : Oui (accès, rectification, opposition aux décisions automatisées).

1. Votre système nécessite-t-il un audit de conformité avant déploiement ? Par qui ?
Oui évidemment, par le DPA de préférence ou l'équivalent local

2. Les personnes affectées par les décisions ont-elles un droit de recours ?
Oui, ils ont un droit de recours en cas de décision automatisée ayant un réel effet significatif

3. Quel organisme de contrôle surveille ce type de système dans votre secteur (CNIL, ANC, ANSSI…) ?
La CNIL est l'organisme de contrôle pour ce type de système, et potentiellement l'ANSSI également pour la partie « sécurité » de l'IA